Defending the Number

Making an SBOM → CRA Decision You Can Explain Later

Andrey Lukashenkov | Vulners

NSSS Fall 2026 | Stockholm | 5 November 2026

Before I start

Findings flagged as exploited in the wild, in this analysis:

1 *or* **13**

Same image. Same SBOM. Same day.

1 or 13 candidates for a 24-hour report. Each tool applies matching and disposition rules it does not state. Which number you report is ***your*** decision. **This talk covers the four artefacts that let you explain it: what you matched, what you dropped, what you assumed, what evidence you kept.**

What I'm citing, and what I built

Not a lawyer, and definitely not ***your*** lawyer. An engineer's reading of the documents.

On my slides	Document	What it's worth
Art. · Annex	Regulation (EU) 2024/2847	Binding law
GUIDANCE §	C(2026) 5252 final, 27 Jul 2026	Published; adoption pending. Non-binding
ENISA SBOM §	Technical Advisory for SBOM, v1.10, Oct 2026	Advisory. May exceed the CRA
CISA 2026	2026 Minimum Elements for an SBOM, 29 Jul 2026	18 agencies. No EU legal force

Only the first one is law. The rest explain it. I'm checking what the tools actually do against both.

The test subject

One vulnerable app, two base images, four SBOMs. Everything else is held still.

insecure-app a Flask app with deliberately old pins: aiohttp 3.9.1, cryptography 3.3.2, requests 2.19.1, urllib3 1.23

+ Docker CLI with buildx and compose, which is where the Go modules come from

two builds FROM ubuntu:20.04 (past standard support) and ubuntu:24.04 — same day, same source tree. 685 and 617 components

two SBOMs each syft 1.54.1 and trivy 0.76.0 → CycloneDX 1.7. 541 and 535 deduplicated PURLs

five columns OSV · Src OSV · Grype · Trivy · Vulners

reproducible SBOMs, scanner configs and the comparison harness are all committed

WHAT VARIES, AND WHAT DOES NOT

Held constant
The image, the source tree, the day. Two measurements never differ because the thing under test moved.

Variable 1 — who wrote it
syft or Trivy, so two documents describe each image. Both claim CycloneDX 1.7.

Variable 2 — who read it
Five scanner columns over each document. Two of them are the same service in different modes.

What counts as a finding
A unique CVE or GHSA ID. USN / LSN / GO / UBUNTU-CVE advisory wrappers are excluded — an advisory is a notice about CVEs, not a vulnerability. 35 excluded on 20.04.

What the four documents contain

All four declare CycloneDX 1.7. They disagree about what to record.

	syft 20.04	Trivy 20.04	syft 24.04	Trivy 24.04
Components	685	687	617	619
…with a PURL	684	683	616	615
…with a CPE	661	0	602	0
…with a hash	0	39	0	27
…with a supplier	0	293	0	249
…with a licence	331	276	272	223
Dependency entries	280	688	233	620
deb packages	293	293	249	249
…source package recorded	229	293	194	249
sbomqs CISA-2026 score	**5.0**	**5.6**	**5.0**	**5.5**

Both record the deb source package — in different places. syft writes it as an `upstream=` PURL qualifier; Trivy writes `aquasecurity:trivy:Src*` properties. Every CPE here was generated by the SBOM tool — neither image supplied one.

Who wrote the SBOM — and who read it?

Findings per column, for each of the four documents.

SBOM	OSV	Src OSV	Grype	Trivy	Vulners	All 5
20.04 syft	510	6,159	**721**	235	549	**235**
20.04 trivy	510	6,159	**499**	236	549	**235**
24.04 syft	282	5,032	395	**210**	319	**210**
24.04 trivy	282	5,032	276	**4,890**	319	**210**

Which number you get depends on who wrote the inventory ***and*** who read it.
And the document Grype does worse on scored higher on CISA 2026.

Scanned by OSV · Grype 0.121.0 · Trivy 0.76.1 · Vulners audit v4

ARTEFACT 1 — WHAT YOU MATCHED

The generator, its flags, the SBOM file, the scanner, the scanner's mode, and the database state — pinned together as one unit. Not “we scanned the image.”

Same facts, two dialects

One public API, queried directly. Two normalisations, the second stacked on the first.

OSV · binary mode

move 1 — epoch inline

20.04 510 = 510

24.04 282 = 282

identical, to the ID

Src OSV · source mode

move 2 — + source lookup

20.04 6,159 = 6,159

24.04 5,032 = 5,032

identical, to the ID

Move 1 — the epoch. Trivy writes ?epoch=, syft writes it inline, and OSV ignores ?epoch= — so the harness puts it inline for both.
Move 2 — the source package. Read from syft's upstream= qualifier or Trivy's aquasecurity:trivy:Src* properties.
Both ask api.osv.dev itself — same API, same queries, both documents.

Same findings, not just the same count — OSV, Src OSV, Vulners, on both images.
Grype and Trivy could both be invariant here. Each reads only its own vendor's spelling.

Fifty lines in a harness, against a public API. Anyone can re-run it on their own documents.

PyPI and Go agree. The debs don't.

Findings per column on the 20.04 syft document, split by ecosystem.

Column	PyPI + Go	deb	deb + PyPI	total
OSV	219	268	23	510
Src OSV	219	5,916	24	6,159
Grype	215	483	23	721
Trivy	214	0	21	235
Vulners	231	294	24	549
in this document	*233*	*5,919*	*24*	*6,176*

A PyPI or Go package has one name. A deb has two — the binary you install and the source it was built from — and only one of them is what the vendor files its advisories against.

> **Everything after this slide is about the deb column.** Trivy's zero there is the end-of-service refusal — its whole 20.04 total is PyPI and Go.

deb + PyPI = one CVE on code Ubuntu ships twice · all 4 documents give the same shape

One package, two identities

syft records python3-pip on 24.04 twice: as the Ubuntu binary, and as the PyPI files it ships.

Same files, recorded as	OSV	Src OSV	Grype	Trivy	Vulners
PyPI pip@24.0	6	6	6	6	6
deb python3-pip	12	19	17	12	14

Same files. As a PyPI package all five columns return 6; as the Ubuntu binary they return 4 different numbers.
The generator made this choice before any scanner ran — it recorded both identities, and nothing downstream says which one your report counted. A generator that recorded only one would have given you a single number and no way to know it was a choice.

Who resolves package identity?

Only the columns that read the SBOM's source fields move under the swap.

Column	Where binary → source is resolved	syft → Trivy
OSV	Nowhere — the PURL as the SBOM spells it	invariant
Src OSV	**In the SBOM — reads BOTH dialects, normalised to one query**	**invariant**
Grype	In the SBOM — syft's upstream= qualifier only	721 → 499 · 20.04
Trivy	In the SBOM — its own aquasecurity:trivy:Src* properties	210 → 4,890 · 24.04
Vulners	Server-side — binary name → source via Ubuntu provenance → Ubuntu CVE, then filtered by USN visible= true where one exists	invariant

Invariance is architecture, not correctness. OSV never resolves; Vulners resolves outside the document, and inherits Ubuntu's inherits Ubuntu's opinions along with its answers.

Sources carry CVEs, fixes name binaries

linux-libc-dev is 91.6% of this document's findings — 4,628 of 5,054, 24.04 Trivy SBOM.

Column	Resolves binary → source	Checks the fix's displayed list	On linux-libc-dev
OSV	no — the PURL as written	—	0
Src OSV	yes — from the SBOM	no	4,628
Grype	no — can't read this dialect	—	0
Trivy	yes — its own dialect	no	4,596
Vulners	yes — server-side	yes	0

The CVE record names no binary. The fix displays exactly one kind.
Ubuntu keys the CVE to a source package and a per-release status, with no binary list at all. The notice that fixes it marks which binaries it *displays* — and across every kernel notice here that list is `linux-image-*`. linux-libc-dev is in the rebuild 117 times and displayed **never**.

CPE names products, not binaries

syft invents a CPE for 661 of 685 components. Trivy emits none.

On linux-libc-dev	What the identity says
syft writes	cpe:2.3:a:linux-libc-dev:linux-libc-dev:5.4.0-216.236
Vendor and product	both the binary package name — no such NVD product exists
NVD, for CVE-2022-0995	cpe:2.3:o:linux:linux_kernel < 5.10.106
Products it names	24 — the kernel, Fedora, nine NetApp appliances. No Ubuntu, no binary.
So a match needs	binary name → upstream product, and distro version → upstream version

The same two failure modes, in different notation.
Leave the CPE as syft wrote it and it matches nothing. Resolve it, and NVD hands you every CVE attributed to linux_kernel — because an applicability statement names a *product*, not the binaries a distribution ships from it. Neither scheme carries a binary-level statement to filter on.

Naive mapping manufactures candidates

Without the displayed-list check, linux-libc-dev inherits the Linux kernel's KEV CVEs.

	20.04	24.04
Findings on linux-libc-dev	5,425	4,628
Share of the document	87.8%	91.6%
Exploited in the wild among them	11 of the 13	4 of the 6
Kernel the image actually runs	**none — headers only**	none — headers only

Every one of these is a reporting candidate until you write down why it is not.
GUIDANCE §235 — a vulnerability reported or found must be investigated, and its applicability confirmed. By you.

Eleven reporting candidates on a package with no executable code. Trivy surfaces the same class on 24.04; Grype and Vulners report nothing here.

ARTEFACT 2 — WHAT YOU DROPPED
The exclusion rule in writing: scope, date, the ground it rests on, the count it suppressed, the exceptions you reviewed by hand — and, where a notice exists, the binary it displays instead.

Why each line misses what it misses

24.04 syft, deb findings, linux-libc-dev removed — every line accounts for the same 266.

Column	reports	wrong dialect	no source step	Ubuntu's status	neither	total
OSV	**140**	—	125	—	1	*266*
Src OSV	**262**	—	—	—	4	*266*
Grype	**255**	—	—	—	11	*266*
Trivy	**71**	84	—	108	3	*266*
Vulners	**159**	—	—	105	2	*266*

Same findings, five partitions of them. OSV never resolves binary → source and loses 125. Trivy and Vulners honour a stated Ubuntu status and set aside 108 and 105. Trivy loses 84 more to a document it cannot fully read.

neither = 16 unexplained, plus 5 the vendor states nothing about or fixes without naming the binary.

You chose a position, not a scanner

Two independent axes. OSV, Src OSV, Grype, Trivy and Vulners partition differently on each.

Column	Resolves binary → source?	Honours Ubuntu's status?
OSV	no	no
Src OSV	yes — from the SBOM, both dialects	no
Grype	yes — syft dialect	no
Trivy	yes — own dialect	yes
Vulners	yes — server-side, from the distro	yes

No “who is most accurate” ranking survives both axes. The disposition split is measured: 202 CVEs on 20.04 and 107 on 24.04 20.04 and 107 on 24.04 where OSV, Src OSV and Grype report and Trivy and Vulners stay silent — **73–85% of the ones Ubuntu the ones Ubuntu has a row for sit at needs-triage**, which means Ubuntu has not decided yet.

> **Neither position is wrong.** A distro's decision not to patch is not a statement that the code is unreachable in your product — and **GUIDANCE §235** makes confirming that your job.

What Ubuntu says about all of them

Every deb finding, linux-libc-dev removed — 494 on 20.04, 266 on 24.04.

What Ubuntu says, for this release	20.04 — 494	24.04 — 266
affected — fix released	209 — 42.3%	119 — 44.7%
affected — no fix yet	91 — 18.4%	38 — 14.3%
not yet assessed — needs-triage	146 — 29.6%	91 — 34.2%
will not fix — ignored	43 — 8.7%	13 — 4.9%
not affected	5 — 1%	2 — 0.8%
no statement for this release	0 — 0%	3 — 1.1%

Ubuntu confirms 300 of 494 affected on 20.04 and 157 of 266 on 24.04.
But 207 of 209 of focal's released fixes are +esm — behind Pro — against 118 of 119 in noble's plain archive.

Ubuntu has a view on almost all of them, and has not reached one on 29.6%. The disagreement is not about missing vendor data. It is about what to do with the data that exists.

Same packages, opposite channel

linux-libc-dev excluded — this is the rest of the image, on packages the app ships.

Source package	20.04 — plain / Pro-only	24.04 — plain / Pro-only
binutils	0 / 55	39 / 0
expat	0 / 36	31 / 0
curl	0 / 29	15 / 0
perl	0 / 22	12 / 0
All packages — 65 / 50 sources	**60 / 452**	**257 / 19**

When a release leaves standard support, its vulnerability records are re-filed under Ubuntu Pro.
They stay public — every figure here was read without a subscription. What changes is the attribution: a query scoped to plain 20.04 returns nothing for 83% of them. Ubuntu Pro sells the fix. The records are free either way.
GUIDANCE §210 — reporting obligations continue after standard support ends. A plain-release query stops returning the data.

Not uniform: pcre2 is the exception on 20.04 — 8 findings, all with a plain-release record. The 60 are real, just rare.

Who still reports a Pro-only record?

Every real-package CVE on 20.04 — 512 of them, 88.3% filed under Pro.

Column	20.04 plain	20.04 Pro-only	20.04 reports	24.04 reports
OSV	30	258	**288**	154
Src OSV	60	452	**512**	276
Grype	54	447	**501**	269
Trivy	3	15	**18**	85
Vulners	30	284	**314**	169

Trivy reports 18 of 512 here, 85 of 276 on 24.04. It honours end-of-service.

Taking the kernel out shrinks the number. It does not settle it. Src OSV goes 6,159 → 734 on 20.04 once linux-libc-dev is excluded, and OSV, Src OSV, Grype, Trivy and Vulners still agree on only 235 of 751.
On an end-of-service release, which channel your scanner reads decides the rest.

20.04 syft · unique CVE ids · linux-libc-dev excluded · includes debs that also ship as PyPI.

What you can cite, and what you can't

Two comfortable outs — one wrong, one that turns out to be documented.

The ground you would reach for	What the vendor's data says
“ Pro records don't apply to me”	Wrong, and the columns agree: 4 of five report them anyway, up to 452 of the 452.
“ The fix notice will say if my binary is in scope”	It does — for the 44% that have one. Every kernel notice displays linux-image-*, never the headers.
“ A headers package contains no code that executes”	**Citable for those. For the other 56% there is no notice, so nothing to cite.**

Exclude, and you drop 5,425 findings — eleven flagged as exploited in the wild. For 44% you can cite the notice that fixes them and displays something else; for the rest it is judgment.
A Pro-only record is the opposite of an out: OSV, Src OSV, Grype and Vulners all report it as affected.

One CVE, two upstream advisories

cryptography 3.3.2 — 14 findings, 11 unanimous, 2 where the upstream records disagree.

Upstream record	What it says about CVE-2026-69249	At 3.3.2
PYSEC-2026-3553	affected from 0, fixed 49.0.0	affected
GHSA-jwv3-5hgf-82ww	affected from 42.0.0, fixed 49.0.0	not affected

What the columns do with that	
Hand you the choice — OSV, Src OSV, Vulners	report the record whose range matches, with its source attached
Make it silently — Grype, Trivy	follow the GitHub advisory. Nothing in the output says a source disagreed

The disagreement is upstream. The tool decides whether you ever see it.

ARTEFACT 3 — WHAT YOU ASSUMED

The assumption register: which source wins when two disagree, and the timestamp of each one you relied on — written down before the disagreement, not during the audit.

Which document, and whose identity?

CVE-2026-111497 · libbrotli1 · CVSS 9.8, EPSS 82.6% — exploited in the wild.

Column	20.04 syft	20.04 trivy	24.04 syft	24.04 trivy	Why
OSV	no	no	no	no	queries the binary name libbrotli1
Src OSV	yes	yes	yes	yes	resolves to source brotli, always
Grype	yes	no	yes	no	reads syft's upstream= , not Trivy's Src*
Trivy	no	no	no	yes	own Src* props; skips end-of-service 20.04
Vulners	yes	yes	yes	yes	resolves source server-side

Ubuntu fixed it, and the notice displays libbrotli1 by name.

The is_visible test that let the kernel headers go keeps this one in — there is no ground to drop it.
So the only open question is which document you scanned, and which column read it.

Not one of the four documents gets a unanimous answer, and Grype and Trivy answer differently depending on which document they read. **Nothing here is a scanner being wrong.**
Every cell is a column honouring a different rule about what libbrotli1 is — and the ones that flip, flip on who wrote the document, not on what the scanner knows.

Which list, and whose number?

CVE-2024-23334 · aiohttp 3.9.1 · EPSS 76.9% — reported by all five columns.

Asked	Answer
In CISA's KEV catalogue?	No
In ENISA's EU KEV list?	No
In VulnCheck KEV?	Yes — and that is where the flag comes from
What is the underlying evidence?	Cyble saw scanning from a ShadowSyndicate-linked IP; no attacks seen
Whose severity?	CVSS 7.5 at NVD · 5.9 at EUVD
What does ENISA SBOM §4.1.2 say?	Check "configured vulnerability databases". It names none — not even EUVD

Art. 3(42) asks for reliable evidence that a malicious actor ***has exploited*** it. This one is on no government list, and you have to make you have to make the call. It is one of two findings that reach the Article 14 question — the one they all agreed on.

ARTEFACT 4 — WHAT EVIDENCE YOU KEPT

The list you checked, the scorer the number came from, and the advisory IDs kept beside the finding — not the summary count. It costs one column in a table.

What survives to Article 14

The 20.04 syft document. The same filters, in the same order, applied to every column.

Filter	OSV	Src OSV	Grype	Trivy	Vulners
Matched against the SBOM	510	6,159	721	235	549
CVSS ≥ 7.0 or EPSS ≥ 0.30	243	2,751	345	124	265
EPSS ≥ 0.10	5	14	7	3	5
Flagged exploited in the wild	1	13	2	1	2
… after the linux-libc-dev exclusion	**1**	**2**	**2**	**1**	**2**

Two findings reach Article 14 — and the columns split on one of them.
All five report CVE-2024-23334; 3 of 5 report CVE-2026-111497 in libbrotli1, EPSS 82.6%.

> **The last row is the one you have to defend.** Without it the Src OSV column reports 13: 11 linux-libc-dev CVEs flagged exploited in the wild, each one a 24-hour clock. That row is artefact 2 — scope, date, ground, and the count it suppressed.

One app · one distro family · two generators · five columns. I'm claiming the shape, not the rates.

Four artefacts

What you hand to an authority that asks why a given CVE is not in your record.

WHAT YOU MATCHED
Generator, flags, SBOM file, scanner, scanner mode, database state — pinned as one unit

WHAT YOU DROPPED
The exclusion rule: scope, date, ground, the count it suppressed, the exceptions you reviewed — and, where a notice exists, the binary it displays instead

WHAT YOU ASSUMED
The assumption register: which source wins, and the timestamp of each one you relied on

WHAT EVIDENCE YOU KEPT
The list you checked, the scorer the number came from, and the advisory IDs beside the finding

Your defence is in the process

Sources will contradict.
You will have to be opinionated.
Your CRA defence is in the process, not the number.

Conformity is per release, not once.

One question for you

Who here can tell me how much their scan output moves
week to week, with the artifact frozen?

That is the number a market surveillance authority would ask for.

Andrey Lukashenkov · Vulners
SBOMs, scanner configs and the comparison harness are reproducible from committed data.